



Informe

Evaluación sumativa final

Curso	Uso de técnicas y estrategias de ciberseguridad en la identificación y análisis de amenazas digitales
Nombre del alumno/a	Javier Ignacio Cerda Salas

Caso de Estudio: Empresa de Salud en Riesgo

La siguiente historia es completamente ficticia y fue creada exclusivamente para materias de evaluación de este curso.

El reloj marcaba las dos de la madrugada cuando mi teléfono emitió un sonido estridente, rompiendo la calma de la noche. Sabía que esa llamada no presagiaba nada bueno. Como jefe de seguridad de una de las empresas de salud más grandes del país, ya estaba acostumbrado a estas interrupciones intempestivas, pero nunca llegaban a ser menos perturbadoras.

Contesté el teléfono y escuché la voz urgente de Carla, nuestra analista de ciberseguridad. “Tenemos un problema, y es grave”, dijo sin preámbulos.

El sistema de monitoreo había detectado actividad inusual en los servidores. Varios intentos fallidos de acceso y un volumen anormal de tráfico saliente sugerían una intrusión. Sabía que no era un simple error. En el mundo digital, las casualidades rara vez existían.

La empresa, que por razones obvias mantendré anónima, era una gigantesca entidad en el ámbito de la salud. Su infraestructura tecnológica, sin embargo, era una amalgama de sistemas modernos y obsoletos, una herencia de décadas de crecimiento y adquisiciones. Este legado de tecnologías incompatibles y vulnerables representaba un riesgo que, aunque identificado, nunca había sido totalmente mitigado debido a restricciones presupuestarias y políticas internas.

Mientras me dirigía a la oficina, repasaba mentalmente las vulnerabilidades conocidas. Los sistemas críticos, aquellos que contenían datos médicos sensibles, se ejecutaban en servidores con software desactualizado, y las aplicaciones internas, muchas desarrolladas en lenguajes ya obsoletos, no recibían actualizaciones de seguridad desde hacía años.

Al llegar, el equipo de respuesta a incidentes ya estaba reunido. Carla me recibió con un resumen rápido: “Han logrado acceder a una de las bases de datos antiguas, la que contiene los historiales médicos digitalizados antes del 2010. Parece que están intentando extraer información, pero aún no sabemos con qué propósito”.

Mis sospechas se confirmaron al revisar los registros de actividad. Un grupo de ciberdelincuentes, posiblemente patrocinados por una nación-estado, había encontrado una puerta trasera en uno de nuestros sistemas legados, un servidor que ejecutaba una versión obsoleta de Windows. Una vez dentro, se habían movido lateralmente, explorando nuestra red interna como un virus que busca su camino hacia el torrente sanguíneo.

Los atacantes eran meticulosos. Sus movimientos eran precisos y calculados, evadiendo nuestras medidas de detección más básicas y aprovechando cada brecha que encontraban. No era la primera vez que lidiábamos con ciberdelincuentes, pero este grupo parecía jugar en una liga diferente.

“Necesitamos contenerlos antes de que causen más daño”, le dije a Carla. “Aísla el servidor comprometido y comienza el análisis forense. Necesitamos saber exactamente qué han tocado y hasta dónde han llegado”.

El equipo se puso en marcha. Pero, incluso mientras trabajaban, sabía que estábamos en una carrera contra el tiempo. Cada minuto que pasaba significaba más datos en riesgo, y en el sector de la salud, esos datos no eran solo números y letras. Eran historias de vida, confidenciales y críticas.

Nuestra primera medida fue desplegar una serie de trampas digitales. Configuramos sistemas señuelo, con datos falsos, diseñados para atraer y atrapar a los intrusos. Estos honeypots eran nuestra última línea de defensa, y esperábamos que nos dieran el tiempo suficiente para reforzar nuestras verdaderas defensas.

Los delincuentes mordieron el anzuelo. Sus movimientos se volvieron más frenéticos, como si supieran que el tiempo se les agotaba. Fue en ese momento cuando logramos identificar una vulnerabilidad en su metodología. Utilizaban un malware que se comunicaba con un servidor de comando y control (C2) externo, enviando pequeñas cantidades de datos encriptados.

A medida que profundizábamos en el análisis, descubrimos que el ataque inicial no provenía únicamente de una puerta trasera en un sistema legado. Los ciberdelincuentes habían explotado vulnerabilidades en varios sistemas web e integraciones expuestas a Internet. Usaban exploits conocidos con CVE (Common Vulnerabilities and Exposures) que ya tenían soluciones publicadas, pero que aún no habíamos implementado por la falta de recursos y atención.

Identificamos varios vectores de ataque, entre ellos:

1. **RCE (CVE-2011-2196):** Una vulnerabilidad que puede permitir la ejecución remota de comandos sobre componentes desarrollados con el framework seam en lenguaje java.
2. **Desbordamiento de búfer (CVE-2018-5678):** Una falla en uno de los módulos de integración que conectaba nuestros sistemas internos con aplicaciones de terceros. Este desbordamiento de búfer permitió a los atacantes ejecutar código malicioso en el sistema afectado, brindándoles acceso de administrador y la capacidad de moverse lateralmente dentro de nuestra red.
3. **Cross-Site Scripting (XSS) (CVE-2024-340701):** Explotaron una debilidad en nuestro portal web que permitía la inserción de scripts maliciosos. Utilizando XSS, los atacantes lograron capturar las credenciales de acceso de nuestros empleados cuando estos interactuaban con las páginas comprometidas, facilitando aún más su incursión en sistemas internos.

4. **Remote Code Execution (CVE-2021-44228 - Log4Shell):** Una vulnerabilidad crítica en la biblioteca de registro de Java Apache Log4j que permite la ejecución remota de código. Los atacantes podían enviar una solicitud especialmente diseñada a la aplicación afectada, lo que les permitía tomar el control del servidor y acceder a datos sensibles.

5. **File Inclusion (CVE-2010-1999):** Una vulnerabilidad en un sistema web basado en PHP que permitía a los atacantes incluir archivos maliciosos a través de parámetros de URL manipulados. Esto podía resultar en la ejecución de código no autorizado en el servidor.

6. **Deserialización Insegura (CVE-2020-9484):** Una vulnerabilidad en Apache Tomcat que permitía la deserialización insegura de datos, facilitando a los atacantes la ejecución de código arbitrario en el servidor Java afectado.

7. **Insufficient Authentication (CVE-2020-13942):** Una vulnerabilidad en Apache OFBiz, un software empresarial basado en Java. La falta de autenticación adecuada permitía a los atacantes eludir la seguridad y ejecutar comandos arbitrarios en el sistema.

Mientras nuestros especialistas parcheaban frenéticamente estas vulnerabilidades, los atacantes lanzaron una campaña de phishing, dirigida específicamente al equipo de tecnología. El correo electrónico, cuidadosamente diseñado, aparentaba ser una comunicación interna importante y contenía un enlace que, al hacer clic, instalaba un malware diseñado para capturar contraseñas y abrir una puerta trasera adicional.

Gracias a las capacitaciones continuas y simulaciones de phishing que habíamos implementado en la empresa, ninguno de nuestros empleados cayó en la trampa. La mayoría reportó el correo a nuestro departamento de seguridad, lo que nos permitió rastrear su origen y fortalecer nuestras defensas contra ese vector de ataque.

Decidimos atacar la raíz del problema. Mientras el equipo de análisis trabajaba para identificar la naturaleza del malware, nuestros especialistas en redes rastrearon la comunicación del C2. Descubrimos que estaba alojado en una serie de servidores proxy en varios países, pero el origen se remontaba a una ubicación en Europa del Este.

Utilizando herramientas de contrainteligencia cibernética, conseguimos infiltrar uno de los servidores proxy y recopilar información sobre el grupo atacante. Eran conocidos como “Medusa”, un colectivo de hackers con antecedentes de ataques a instituciones de salud y

financieras. Sus motivos eran claros: lucrar con la venta de datos personales y médicos en el mercado negro.

Nuestra jugada final fue arriesgada, pero necesaria. Coordinamos con las autoridades internacionales para lanzar un contraataque simultáneo. Mientras ellos desmantelaban físicamente el servidor en Europa del Este, nosotros implementamos una purga digital en nuestra red, eliminando cualquier rastro del malware y reforzando nuestras defensas.

El ataque fue finalmente contenido, pero el daño ya estaba hecho. Aunque logramos prevenir la extracción masiva de datos, sabíamos que habían conseguido llevarse una cantidad significativa de información.

Al final, este incidente fue una lección amarga, pero necesaria. La obsolescencia tecnológica había sido nuestro mayor enemigo, y nos dejó expuestos a una vulnerabilidad que casi destruye nuestra reputación y confianza. Desde entonces, la empresa se embarcó en una completa renovación tecnológica, modernizando sus sistemas y adoptando una cultura de ciberseguridad proactiva.

Para mí, fue un recordatorio de que, en el mundo de la ciberseguridad, la batalla es constante. Los atacantes evolucionan, y nuestras defensas deben hacerlo también. No podemos darnos el lujo de descansar en los laureles, porque en cada línea de código obsoleta, en cada sistema no parcheado, acecha la próxima amenaza.

Esta historia, aunque llena de tensiones y desafíos, es solo una de las muchas que he vivido en mi carrera. Y aunque las cicatrices de aquella noche aún persisten, me sirven como recordatorio de que la verdadera seguridad no es solo una cuestión de tecnología, sino de constante vigilancia y preparación.

Playground de aplicación con graphql:

```

# Write your query or mutation here
query {
  medicalCenter(ids: 1, search: "") {
    name
  }
}

```

```

{
  "error": {
    "errors": [
      {
        "message": "Unknown argument 'ids' on field 'Query.medicalCenter'. Did you mean 'id'?",
        "locations": [
          {
            "line": 2,
            "column": 17
          }
        ],
        "extensions": {
          "code": "GRAPHQL_VALIDATION_FAILED",
          "exception": {
            "stacktrace": [
              "GraphQLError: Unknown argument 'ids' on field 'Query.medicalCenter'. Did you mean 'id'?",
              "    at Object.Argument (/opt/dalca/api-gateway/node_modules/graphql/validation/rules/knownArgumentNamesRule.js:46:12)",
              "    at Object.enter (/opt/dalca/api-gateway/node_modules/graphql/language/visitor.js:323:29)",
              "    at Object.enter (/opt/dalca/api-gateway/node_modules/graphql/utilities/TypeInfo.js:376:25)",
              "    at visit (/opt/dalca/api-gateway/node_modules/graphql/language/visitor.js:243:26)",
              "    at Object.validate (/opt/dalca/api-gateway/node_modules/graphql/validation/validate.js:89:24)",
              "    at validate (/opt/dalca/api-gateway/node_modules/apollo-server-core/dist/requestPipeline.js:233:34)",
              "    at Object.<anonymous> (/opt/dalca/api-gateway/node_modules/apollo-server-core/dist/requestPipeline.js:119:42)",
              "    at Generator.next (<anonymous>)",
              "    at fulfilled (/opt/dalca/api-gateway/node_modules/apollo-server-core/dist/requestPipeline.js:15:58)",
              "    at runMicrotasks (<anonymous>)"
            ]
          }
        ]
      }
    ],
    "locations": [
      {
        "line": 2,
        "column": 28
      }
    ],
    "extensions": {
      "code": "GRAPHQL_VALIDATION_FAILED",
      "exception": {
        "stacktrace": [

```

Carpetas de repositorios de código fuente de aplicativo

```

← → ↺ 🏠 🔒 🔑 https://github.com/mundo.../.git/config
Import bookmarks... Kali Linux Kali Tools Kali Docs Kali Forums Kali N
[core]
    repositoryformatversion = 0
    filemode = true
    bare = false
    logallrefupdates = true
[remote "origin"]
    url = git@github.com:mundo.../.git
    fetch = +refs/heads/*:refs/remotes/origin/*
[branch "main"]
    remote = origin
    merge = refs/heads/main
[branch "develop"]
    remote = origin
    merge = refs/heads/develop
[branch "development"]
    remote = origin
    merge = refs/heads/development
[branch "main-current"]
    remote = origin
    merge = refs/heads/main-current

```


JBoss Seam Debug Page

This page allows you to browse and inspect components in any of the Seam contexts associated with the current session. It also shows a list of active, long-running conversations. You can select a conversation to view its contents or destroy it.

Conversations

No long-running conversations exist

- Component (org.apache.catalina.jsp_classpath)

bytes	[B@5cb3058b
class	class java.lang.String
empty	false
toString()	/opt/jboss-strix-cl/lib/jboss-common.jar:/opt/jdk1.8.0_221/jre/lib/ext/nashorn.jar:/opt/jboss-strix-cl/lib/concurrent.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp2820740758702288056jasper-jdt.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp6010267457354787906mail-ra.rar:/opt/jboss-strix-cl/server/default/lib/mail-plugin.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp5347722422097435251wsd4j.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp5288160561592831937xmsec.jar:/opt/jboss-strix-cl/server/default/lib/jboss-remoting-int.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp8054814277420870363trove.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/httpcore-4.4.4.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp7809401605815389081jboss-ha-local-jdbc.rar:/opt/jboss-strix-cl/server/default/lib/jboss-ha-local-jdbc.jar:/opt/jdk1.8.0_221/lib/tools.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp345264437434633129sf-impl.jar:/opt/jboss-strix-cl/server/default/lib/hsqldb.jar:/opt/jboss-strix-cl/server/default/lib/c3p0-0.9.1.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp6249433582484953947jettison.jar:/opt/jboss-strix-cl/server/default/lib/commons-codec.jar:/opt/jboss-strix-cl/server/default/lib/groups.jar:/opt/jboss-strix-cl/server/default/deploy/jboss-bean-deployer.jar:/opt/jboss-strix-cl/server/default/lib/boss-sax.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-lang-2.5.jar:/opt/jboss-strix-cl/server/default/lib/mssqlserver.jar:/opt/jboss-strix-cl/server/default/lib/bstf.jar:/opt/jboss-strix-cl/server/default/lib/bossws-framework.jar:/opt/jboss-strix-cl/server/default/lib/bossla-integration.jar:/opt/jboss-strix-cl/server/default/lib/boss-transaction.jar:/opt/jboss-strix-cl/server/default/lib/boss-jr88.jar:/opt/jboss-strix-cl/server/default/lib/jboss-ear:/opt/jboss-strix-cl/server/default/lib/jboss-jaxws-ext.jar:/opt/jboss-strix-cl/bin/run.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/gson-2.8.0.jar:/opt/jboss-strix-cl/server/default/lib/jboss-remoting.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar/wsd4j.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/httpclient-4.5.2.jar:/opt/jboss-strix-cl/server/default/deploy/uid-key-generator.sar:/opt/jboss-strix-cl/server/default/lib/msutil.jar:/opt/jboss-strix-cl/server/default/lib/commons-httpclient.jar:/opt/jboss-strix-cl/server/default/lib/log4j-snm-appender.jar:/opt/jboss-strix-cl/server/default/lib/jboss-common-jdbc-wrapper.jar:/opt/jboss-strix-cl/lib/log4j-boot.jar:/opt/jboss-strix-cl/server/default/lib/bosssx.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/richfaces-api.jar:/opt/jboss-strix-cl/server/default/lib/bcel.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp143730885570732731jboss-aspect-library-jdk50.jar:/opt/jboss-strix-cl/server/default/lib/sgplogmodule.jar:/opt/jboss-strix-cl/server/default/deploy/jboss-web-deployer.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp7609895655772982961jxb-impl.jar:/opt/jboss-strix-cl/server/default/lib/bsh.jar:/opt/jboss-strix-cl/server/default/lib/bosts-common.jar:/opt/jboss-strix-cl/server/default/lib/scheduler-plugin.jar:/opt/jboss-strix-cl/server/default/lib/c3p0-0.9.1.2.jar:/opt/jboss-strix-cl/server/default/lib/ehcache-1.3.0.jar:/opt/jboss-strix-cl/server/default/lib/hibernate-entitymanager.jar:/opt/jboss-strix-cl/server/default/lib/quartz.jar:/opt/jboss-strix-cl/server/default/lib/servlet-api.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp2702549096640012381jboss-bean-deployer.jar:/opt/jboss-strix-cl/server/default/deploy/tmp7780297899782095373jboss-ha-xa-jdbc.rar:/opt/jboss-strix-cl/lib/jboss-jmx.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp7809401605815389081jboss-ha-local-jdbc.rar:/opt/jboss-strix-cl/server/default/lib/bossmq.jar:/opt/jboss-strix-cl/server/default/lib/ei-api.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/jettison-1.3.3.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp3206605422479385596pluggable-instrumentor.jar:/opt/jboss-strix-cl/lib/endorsed/xalan.jar:/opt/jboss-strix-cl/server/default/lib/xmlentitymgr.jar:/opt/jdk1.8.0_221/jre/lib/ext/sunec.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/jersey-core-1.18.1.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp1945405027547889612Fastrifoset.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp42938668923918906jbossweb-extras.jar:/opt/jboss-strix-cl/server/default/lib/jboss-management.jar:/opt/jdk1.8.0_221/jre/lib/ext/localedata.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp933714672408984728jboss-faces.jar:/opt/jboss-strix-cl/server/default/deploy/tmp7515703658319402580jms-ra.rar:/opt/jboss-strix-cl/server/default/lib/javassist.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp2098981240331967336bossws-core.jar:/opt/jboss-strix-cl/server/default/lib/jboss.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/Strix-Server.jar:/opt/jboss-strix-cl/server/default/lib/jds-1.2.2.jar:/opt/jboss-strix-cl/server/default/lib/properties-plugin.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar/bossws-beans:/opt/jboss-strix-cl/server/default/lib/jboss-jsr77.jar:/opt/jboss-strix-cl/server/default/lib/jboss-hibernate.jar:/opt/jboss-strix-cl/server/default/lib/mail.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp8448369618992197939jstl.jar:/opt/jboss-strix-cl/server/default/lib/commons-collections.jar:/opt/jboss-strix-cl/server/default/deploy/tmp3734631342316329318jboss-annotations-ejb3.jar:/opt/jboss-strix-cl/server/default/lib/bsh-deployer.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp4510385589196545486jboss-local-jdbc.rar:/opt/jboss-strix-cl/server/default/lib/jnpserver.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/dx-java-1.0.36.jar:/opt/jboss-strix-cl/server/default/lib/mysql-connector-java-5.1.7-bin.jar:/opt/jboss-strix-cl/server/default/lib/autonumber-plugin.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp6633537115574248853jboss-jaxb-intros.jar:/opt/jboss-strix-cl/lib/endorsed/serializer.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp3168224274449491836jboss-xa-jdbc.rar:/opt/jboss-strix-cl/server/default/lib/jmx-adaptor-plugin.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp7720250307522630059jboss-microcontainer.jar:/opt/jboss-strix-cl/server/default/lib/jboss-serialization.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp6010267457354787906mail-ra.rar:/opt/jboss-strix-cl/server/default/deploy/tmp7515703658319402580jms-ra.rar:/opt/jboss-strix-cl/server/default/lib/jaxen.jar:/opt/jboss-strix-cl/server/default/lib/ldap.jar:/opt/jboss-strix-cl/server/default/lib/bossha.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar/sax-api.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp3983171315011444537sf-api.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp7446014906736865234jboss-dependency.jar:/opt/jdk1.8.0_221/jre/lib/ext/access.jar:/opt/jboss-strix-cl/server/default/lib/bossws-api.jar:/opt/jboss-strix-cl/server/default/lib/pesmp.jar:/opt/jboss-strix-cl/lib/jboss-system.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-lang-3.1.jar:/opt/jboss-strix-cl/server/default/lib/jboss-jaxws.jar:/opt/jboss-strix-cl/server/default/lib/msbase.jar:/opt/jboss-strix-cl/server/default/deploy/jboss-web-deployer/ROOT.war:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-digester-1.8.jar:/opt/jboss-strix-cl/server/default/deploy/ejb3-deployer.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp8189980666967024182jboss-seam.jar:/opt/jboss-strix-cl/lib/endorsed/xercesImpl.jar:/opt/jboss-strix-cl/lib/jboss-xml-binding.jar:/opt/jdk1.8.0_221/jre/lib/ext/sunec_provider.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar/policy.jar:/opt/jboss-strix-cl/server/default/lib/jsp-api.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/jersey-client-1.18.1.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-io-2.4.jar:/opt/jboss-strix-cl/server/default/lib/cglib.jar:/opt/jdk1.8.0_221/jre/lib/ext/dnsns.jar:/opt/jboss-strix-cl/server/default/deploy/tmp7780297899782095373jboss-ha-xa-jdbc.rar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/jersey-apache-client-1.18.1.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-httpclient-3.1.jar:/opt/jboss-strix-cl/server/default/lib/commons-logging.jar:/opt/jboss-strix-cl/server/default/lib/jboss-srp.jar:/opt/jboss-strix-cl/server/default/lib/dom4j.jar:/opt/jboss-strix-cl/server/default/deploy/jboss-aop-jdk50-deployer.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/Strix.war:/opt/jdk1.8.0_221/jre/lib/ext/sunpkcs11.jar:/opt/jboss-strix-cl/server/default/lib/bindingservice-plugin.jar:/opt/jboss-strix-cl/server/default/lib/hibernate3.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp2765320360306552234jxb-api.jar:/opt/jdk1.8.0_221/jre/lib/ext/cldrdata.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp67250265376207290wstx.jar:/opt/jboss-strix-cl/server/default/lib/bossws-common.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/boss-el.jar:/opt/jdk1.8.0_221/jre/lib/ext/zipfs.jar:/opt/jdk1.8.0_221/jre/lib/ext/fxt.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp180989989868337984jboss-aop-jdk50.jar:/opt/jboss-strix-cl/server/default/lib/sapico.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear:/opt/jboss-strix-cl/server/default/lib/jboss-2ee.jar:/opt/jboss-strix-cl/server/default/lib/jboss-jca.jar:/opt/jboss-strix-cl/server/default/lib/poi-2.5.1-final-20040804.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp4510385589196545486jboss-local-jdbc.rar:/opt/jboss-strix-cl/server/default/lib/jboss-jaxrpc.jar:/opt/jboss-strix-cl/server/default/lib/scheduler-plugin-example.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp367022178571899646stax-api.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp42755621552678254jbossweb-service.jar:/opt/jboss-strix-cl/server/default/conf:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp776919868198955254rockit-pluggable-instrumentor.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/jersey-json-1.18.1.jar:/opt/jboss-strix-cl/server/default/lib/hibernate-annotations.jar:/opt/jboss-strix-cl/server/default/lib/hsqldb-plugin.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-validator-1.4.0.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp4346229212231725424quartz-ra.rar:/opt/jboss-strix-cl/server/default/lib/jboss-vfs.jar:/opt/jboss-strix-cl/server/default/deploy/bossws.sar/bossws-context.war:/opt/jboss-strix-cl/server/default/lib/jboss-monitoring.jar:/opt/jboss-strix-cl/server/default/lib/objdbc14.jar:/opt/jboss-strix-cl/server/default/lib/jboss-ejb3x.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp4226455705726150266jboss-container.jar:/opt/jboss-strix-cl/server/default/lib/bossws-jboss42.jar:/opt/jboss-strix-cl/server/default/deploy/Strix.ear/lib/commons-beanutils-1.8.3.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp4346229212231725424quartz-ra.rar:/opt/jboss-strix-cl/server/default/lib/antlr.jar:/opt/jboss-strix-cl/server/default/lib/activation.jar:/opt/jboss-strix-cl/server/default/lib/bossla.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp3168224274449491836jboss-xa-jdbc.rar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp173661997572498095jbossweb.jar:/opt/jboss-strix-cl/server/default/lib/ejb3-persistence.jar:/opt/jboss-strix-cl/server/default/lib/log4j.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp5108799811634746671policy.jar:/opt/jboss-strix-cl/server/default/lib/jboss-iop.jar:/opt/jboss-strix-cl/server/default/tmp/deploy/tmp8275036037539735091jboss-ejb3.jar

Accesos de Servidor de aplicaciones



Welcome to AS 7

Your JBoss Application Server 7 is running.

[Documentation](#) | [Quickstarts](#) | [Administration Console](#)

[JBoss AS Project](#) | [User Forum](#) | [Report an issue](#)



To replace this page set "enable-welcome-root" to false in your server configuration and deploy your own war with / as its context path.

Inyección SQL, en sistema legado

```

--$ sqlmap -u 'http://10.10.10.10/region.php?regionId=5' --banner --random-agent

[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 14:29:42 /2024-06-08/

[14:29:42] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; AppleWebKit/532.1 (KHTML, like Gecko) Chrome/4.0.219.4 Safari/532.1' from file '/usr/share/sqlmap/data/txt/user-ag
ents.txt'
[14:29:43] [INFO] testing connection to the target URL
[14:29:45] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
[14:29:45] [INFO] testing if the target URL content is stable
[14:29:46] [INFO] target URL content is stable
[14:29:46] [INFO] testing if GET parameter 'regionId' is dynamic
[14:29:47] [INFO] GET parameter 'regionId' appears to be dynamic
[14:29:48] [INFO] heuristic (basic) test shows that GET parameter 'regionId' might be injectable (possible DBMS: 'Microsoft SQL Server')
[14:29:49] [INFO] testing for SQL injection on GET parameter 'regionId'
it looks like the back-end DBMS is 'Microsoft SQL Server'. Do you want to skip test payloads specific for other DBMSes? [Y/n]

for the remaining tests, do you want to include all tests for 'Microsoft SQL Server' extending provided level (1) and risk (1) values? [Y/n]

[14:29:51] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[14:29:51] [INFO] GET parameter 'regionId' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --string="58")
[14:29:51] [INFO] testing 'Generic inline queries'
[14:29:51] [INFO] GET parameter 'regionId' is 'Generic inline queries' injectable
[14:29:51] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[14:29:51] [INFO] GET parameter 'regionId' is 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)' injectable

sqlmap identified the following injection point(s) with a total of 55 HTTP(s) requests:
---
Parameter: regionId (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: regionId=5 AND 4019=4019

Type: inline query
Title: Generic inline queries
Payload: regionId=(SELECT CONCAT(CONCAT(CHAR(113)+CHAR(98)+CHAR(113)+CHAR(107)+CHAR(113)), (CASE WHEN (8639=8639) THEN CHAR(49) ELSE CHAR(48) END)), CHAR(113)+CHAR(122)+CHAR(112)+CHAR(106)+CHAR(113)))

Type: error-based
Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)
Payload: regionId=5 AND 8117 IN (SELECT (CHAR(113)+CHAR(98)+CHAR(113)+CHAR(107)+CHAR(113))+ (SELECT (CASE WHEN (8117=8117) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(122)+CHAR(112)+CHAR(106)+CHAR(113)))

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: regionId=5;WAITFOR DELAY '0:0:5'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: regionId=5 WAITFOR DELAY '0:0:5'
---
[14:30:50] [INFO] testing Microsoft SQL Server
[14:30:50] [CRITICAL] unable to connect to the target URL ('Broken pipe'). sqlmap is going to retry the request(s)
[14:30:52] [INFO] confirming Microsoft SQL Server
[14:30:57] [INFO] the back-end DBMS is Microsoft SQL Server
[14:30:57] [INFO] fetching banner
[14:30:58] [INFO] retrieved: 'Microsoft SQL Server 2012 - 11.0.2100.60 (X64) \n\tFeb 10 2012 19:39:15 \n\tCopyright (c) Microsoft Corporation\n\tEnterprise Edition (64-bit) on Windows NT 6.2 <X64> (Build 9200: )\n'
web application technology: Apache
back-end DBMS operating system: Windows 2012 or 8
back-end DBMS: Microsoft SQL Server 2012
banner:
---
Microsoft SQL Server 2012 - 11.0.2100.60 (X64)
Feb 10 2012 19:39:15
Copyright (c) Microsoft Corporation
Enterprise Edition (64-bit) on Windows NT 6.2 <X64> (Build 9200: )

```

Archivo info.php expuesto

PHP Version 5.1.6 	
System	Linux q352-3818.cafe24.com 2.6.32-754.3.5.el6.x86_64 #1 SMP Tue Aug 14 20:46:41 UTC 2018 x86_64
Build Date	Dec 27 2018 14:07:03
Configure Command	./configure '--prefix=/opt/php' '--with-mysql=/opt/mysql' '--with-mysqli=/opt/mysql/bin/mysql_config' '--with-pdo-mysql=/opt/mysql' '--with-apxs2=/opt/apache/bin/apxs' '--with-curl' '--with-gd' '--with-jpeg-dir=/usr/lib' '--with-freetype-dir=/usr' '--with-png-dir=/usr' '--with-libXpm=/usr/lib64/libXpm.so.4.11.0' '--with-zlib' '--with-zlib-dir=/usr' '--with-gdbm' '--with-gettext' '--with-iconv' '--with-libxml-dir=/usr/lib' '--with-bz2' '--with-mcrypt' '--enable-gd-native-ttf' '--enable-exif' '--enable-ftp' '--enable-magic-quotes' '--enable-sockets' '--enable-sysvsem' '--enable-sysvshm' '--enable-sysvmsg' '--enable-soap' '--enable-mbstring=all' '--enable-bcmath' '--enable-zip'
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/opt/php/lib

Apache Environment

Variable	Value
HTTP_HOST	175.126.232.28
HTTP_USER_AGENT	Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:126.0) Gecko/20100101 Firefox/126.0
HTTP_ACCEPT	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
HTTP_ACCEPT_LANGUAGE	en-US,en;q=0.5
HTTP_ACCEPT_ENCODING	gzip, deflate
HTTP_REFERER	https://www.google.com/
HTTP_CONNECTION	keep-alive
HTTP_UPGRADE_INSECURE_REQUESTS	1
HTTP_PRIORITY	u=1
PATH	/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin:/root/bin:/opt/mysql/bin:/opt/apache/bin:/opt/php/bin
SERVER_SIGNATURE	<address>Apache/2.2.32 (Unix) mod_ssl/2.2.32 OpenSSL/1.0.1e-fips DAV/2 PHP/5.1.6 Server at 175.126.232.28 Port 80</address>
SERVER_SOFTWARE	Apache/2.2.32 (Unix) mod_ssl/2.2.32 OpenSSL/1.0.1e-fips DAV/2 PHP/5.1.6
SERVER_NAME	175.126.232.28
SERVER_ADDR	175.126.232.28
SERVER_PORT	80
REMOTE_ADDR	186.79.123.158
DOCUMENT_ROOT	/home/ice372/www
SERVER_ADMIN	webmaster@thebig.co.kr
SCRIPT_FILENAME	/home/ice372/www/info.php
REMOTE_PORT	58504
GATEWAY_INTERFACE	CGI/1.1
SERVER_PROTOCOL	HTTP/1.1
REQUEST_METHOD	GET
QUERY_STRING	no value
REQUEST_URI	/info.php
SCRIPT_NAME	/info.php

*Material de Apoyo, Hallazgos accesibles de forma pública, encontrados por los analistas:
Debug de aplicación sean.*

JBoss Seam Debug Page

This page allows you to browse and inspect components in any of the Seam contexts associated with the current session. It also shows a list of active, long-running conversations. You can select a conversation to view its

Conversations

No long-running conversations exist

- Component (loggedUsersPool)

class	class net.mecol.xman2.application.LoggedUsersPool_\$\$_javassist_seam_20
component	Component(loggedUsersPool)
pool	[Carolina Cortés (c.cortes1) - Active, Andrea Zuleta (azuleta) - Active, Francisco Aguila (f.aguila) - Active, Nilton Urrea Martinez (nurrea) - Active, Rodrigo Fernández (ro.fernandez) - Active]
users	[Carolina Cortés (c.cortes1) - Active, Andrea Zuleta (azuleta) - Active, Francisco Aguila (f.aguila) - Active, Nilton Urrea Martinez (nurrea) - Active, Rodrigo Fernández (ro.fernandez) - Active]
toString()	net.mecol.xman2.application.LoggedUsersPool@290f3e

- Conversation Context (None selected)

[org.jboss.seam.international.statusMessages](#)

- Business Process Context

Empty business process context

- Session Context

[org.jboss.seam.core.conversationEntries](#)

[org.jboss.seam.international.localeSelector](#)

[org.jboss.seam.international.timeZoneSelector](#)

[org.jboss.seam.security.credentials](#)

[org.jboss.seam.security.identity](#)

[org.jboss.seam.security.rememberMe](#)

[org.jboss.seam.security.ruleBasedPermissionResolver](#)

[org.jboss.seam.web.session](#)

+ Application Context

Índice

<i>Índice</i>	2
<i>Introducción</i>	3
<i>Desarrollo</i>	4
<i>Conclusión</i>	8
<i>Bibliografía</i>	9

Introducción

La transformación digital ha permitido que organizaciones de salud gestionen grandes volúmenes de información sensible mediante infraestructuras tecnológicas complejas que incluyen fichas electrónicas, HIS, LIS, RIS-PAC, así como también, servidores internos y iCloud. Sin embargo, esta misma dependencia ha incrementado significativamente su exposición a amenazas cibernéticas que se dan producto de la manipulación de información sensible y confidencial la cual puede ser utilizada con fines ilegales y fraudulento por ciberdelincuentes. Un ejemplo de ello son los ciberataques ocurridos durante el 2025 al instituto de salud pública de Chile mediante ransomware que es atribuido al grupo Qilin que funciona como RaaS y el caso reciente de Clínica Davila (Qilin Ransomware: De La Disrupción Sanitaria Al Ciberconflicto Global).

El presente informe analiza un incidente crítico de ciberseguridad ocurrido en una empresa de salud, donde actores maliciosos lograron explotar múltiples vulnerabilidades presentes en sistemas legados y plataformas tecnológicas desactualizadas, comprometiendo la confidencialidad e integridad de datos clínicos.

El objetivo principal de este trabajo es identificar, analizar y evaluar las amenazas detectadas, utilizando marcos de referencia reconocidos como STRIDE para el reconocimiento de amenazas, OWASP Top Ten para la categorización de riesgos, MITRE ATT&CK para la identificación de tácticas y técnicas empleadas por los atacantes y CVSS 3.1 para la estimación del nivel de criticidad de las vulnerabilidades. A través de este análisis, se busca no solo comprender el alcance del incidente, sino también evidenciar la importancia de la gestión proactiva de la ciberseguridad en instituciones de salud, donde la protección de la información no solo tiene implicancias técnicas, sino también éticas y sociales.

Desarrollo

- 1. Reconocimiento de amenazas, utilizando modelo STRIDE.** Describa 3 amenazas a los que se enfrenta la empresa de salud, indicando la relevancia de esta.

Amenaza	Descripción
1.Spoofing (suplantación de identidad) Hubo una suplantación de usuarios internos	Como evidencia observada se colocó énfasis en la explotación mediante XSS que corresponde al CVE-2024-340701. Donde los atacantes lograron obtener credenciales válidas de empleados mediante scripts maliciosos cuando había interacción con la página web utilizada como vector, permitiéndoles autenticarse en sistemas internos como usuarios legítimos y evadir controles básicos de seguridad. La relevancia de este hallazgo en el caso se evidencia en la facilitación de accesos no autorizados a sistemas clínicos, lo cual permite movimiento lateral de manera más simple, sin detección y compromete la confianza en los mecanismos de autenticación.
2.Elevación de privilegios. Hubo escaladas de privilegios a nivel de usuario administrador	Como evidencia extraída del caso se puede desprender las siguientes vulnerabilidades encontradas: -Desbordamiento de buffer (CVE -2018-5678). -Remote code execution (CVE-2021 -44228- log4shell). -RCE (CVE-2011-2196). Los atacantes en este caso, tras el ingreso con credenciales legítimas, utilizaron y explotaron las vulnerabilidades en paralelo el desbordamiento de buffer junto con la ejecución remota de código en bibliotecas de java apache log4j y en componentes que fueron desarrollados con framework sean para elevar en primera instancia los privilegios a un usuario administrador y con ello tener acceso tanto a los servidores internos como de terceros para la extracción de información. Es por ello, que la relevancia de este punto radica en que se obtiene un control total en la infraestructura informática y de redes, comprometiendo servidores y sistemas operativos críticos

	en la infraestructura de salud, dificultando la contención del incidente por la superficie abarcada.
3.Information disclosure exposición y divulgación de datos clínicos sensibles	En relación con el caso presentado se puede evidenciar que, tras el acceso a la organización mediante el robo de credenciales, y el compromiso interno tanto de servidores internos y sistemas legacy mediante inyecciones SQL, credenciales robadas y privilegios de administrador. Se realizó una exfiltración de información sensible hacia el servidor C2 del atacante (APT medusa) teniendo esa información en su poder, la utilizan con fines económicos vendiendo mediante mercado negro a diferentes organizaciones tales como aseguradoras y otras organizaciones.

2. **Matriz de Riesgos.** Complete la Matriz de Riesgos, en la cual debe señalar 5 riesgos y describir las amenazas, vulnerabilidades e impactos asociados a este, para ello debe emplear el marco OWASP TOP TEN.

Descripción del Riesgo	Amenaza	Vulnerabilidad	Cat. OWASP Vulnerabilidad	Probabilidad	Impacto	Nivel de Riesgo
1. Compromiso de la red interna por accesos no autorizados El compromiso de la red interna se produce debido a la explotación de vulnerabilidades críticas en sistemas legados y a debilidades en los controles de autenticación, lo que permite a ciberatacantes obtener control sobre servidores internos y sistemas heredados, desplazándose lateralmente dentro de la red y afectando sistemas clínicos críticos. Este riesgo se ve agravado por una gestión deficiente en la implementación de parches de seguridad, lo que evidencia la necesidad de fortalecer	Intrusión por ciberatacantes con altas capacidades y conocimiento en técnicas avanzadas de explotación y penetración de redes.	- Falta en segmentación de la red. - Sistemas operativos de legado sin parchado. - Debilidades en los controles de autenticación.	- A01 Perdida de control de acceso. - A06 Componentes vulnerables y desactualizados.	5/5	5/5	Critico

los controles de acceso, la segmentación de red y la gestión de vulnerabilidades.						
2. Exfiltración de información clínica confidencial Este riesgo se genera como consecuencia de intrusiones en la red interna, facilitadas por inyecciones SQL, elevación de privilegios y robo de credenciales, lo que permite la comunicación de malware con servidores de comando y control (C2). Como resultado, se produce una violación de la confidencialidad de la información clínica resguardada, con posibles sanciones legales y pérdida de confianza institucional, evidenciando la necesidad de mejorar el monitoreo del tráfico de	Malware con comunicación a servidor C2.	• No hay validación correcta de entradas(inyección SQL). • No hay controles de acceso adecuados MFA • Monitoreo insuficiente por SOC.	A09 :Fallas en el registro y monitoreo. A03: inyección.	5/5	5/5	Crítico

red e implementar controles de prevención de fuga de información sensible						
3. Pérdida y corrupción de datos clínicos críticos La pérdida o corrupción de datos clínicos críticos se produce debido a la ejecución de código malicioso y la elevación de privilegios en sistemas operativos legados vulnerables, lo que puede afectar la continuidad operativa y comprometer la seguridad de los pacientes. Este escenario evidencia deficiencias en los controles de integridad de la información y en los mecanismos de respaldo, por lo que resulta necesario fortalecer las políticas y procedimientos de copias de seguridad, así	Manipulación de datos por personal no autorizado. Destrucción de datos	• No hay controles de integridad de datos en la organización. • Ausencia de servidores de respaldo frente a desastres. • Ausencia de respaldos en la nube o de forma física. • Sistemas operativos de legado sin parcheado.	• A08 Fallas en el software y en la integridad de los datos. • A05 configuración de seguridad incorrecta.	3/5	5/5	Alto

como la segregación de privilegios en los sistemas críticos.						
4. Interrupción de los servicios críticos de salud Existe el riesgo de interrupción de los servicios críticos para el funcionamiento de la organización de salud debido a ataques que afectan una infraestructura tecnológica obsoleta basada en sistemas legados y con carencias de redundancia. Esta situación puede generar la indisponibilidad de sistemas informáticos clínicos y retrasos en la atención de los pacientes, evidenciando la ausencia de planes de continuidad operacional y la necesidad de implementar planes de recuperación ante	Interrupción en la disponibilidad de servidores de servicios críticos en el centro de salud.	• Infraestructura lógica de red obsoleta. • Falta de redundancia. • Ausencia de un plan de continuidad operacional frente a desastres.	A06 componentes vulnerables y desactualizados	3/5	5/5	Alto

desastres y alta disponibilidad.						
5. Pérdidas financieras y legales Existe el riesgo de pérdidas financieras y sanciones legales derivadas de incidentes de seguridad que involucren datos médicos sensibles, ocasionados por deficiencias en el gobierno de ciberseguridad y en el cumplimiento normativo. Este escenario podría afectar gravemente la estabilidad financiera y la reputación de la organización, por lo que resulta necesario fortalecer los controles de cumplimiento, las auditorías de seguridad	Ciberataques con impacto en información clínica sensible. Incumplimiento en normativas de seguridad de la información.	- Deficiencias en el gobierno de ciberseguridad. - Baja en el cumplimiento de controles. - Ausencia de auditorías internas y/o externas a la infraestructura de red. - Monitoreo de red insuficiente.	A01 Perdidas de control de acceso. A03 Inyeccion A09 Fallas en el registro y monitoreo	2/5	5/5	Media

y la gestión integral de riesgos.						
-----------------------------------	--	--	--	--	--	--

3. **Tácticas usadas en el ciberataque.** Describa 3 tácticas relevantes identificadas en el incidente, describiendo el cómo fue usada en el ataque.

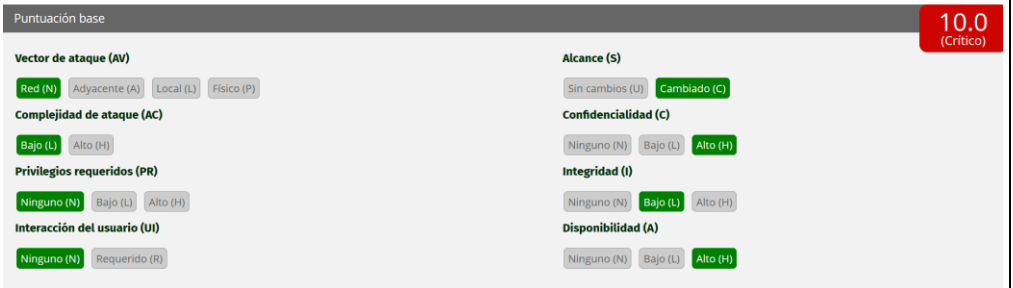
Táctica	Descripción
1. Movimiento Lateral	La utilización de exploit para explotar la vulnerabilidad CVE-2018-5678 , permitió en primer lugar ejecutar código, con dicho código, se le proporciono acceso administrador y con ello el atacante puede moverse dentro del entorno de la red.
2. Ejecucion	Se realizaron desbordamiento de buffer, ataques XSS, y también, la ejecución remota de código a través de la biblioteca de registro de java apache log4j.
3. Exfiltración	Se utilizo un malware que encriptaba los datos y los transmitía a un servidor de tipo C2.

4. **Detección de técnicas.** Emplee Mitre Att&ck y describa 3 técnicas relevantes aplicadas en el incidente, por ciberatacantes y/o por los analistas para la revisión. Debe indicar cómo fue aplicada la técnica y quién la utilizó.

Técnica	Descripción
1.Command and scripting interpreter	En el caso analizado, los ciberatacantes utilizaron la técnica Command and Scripting Interpreter para ejecutar comandos de forma remota una vez comprometidos los servidores internos de la empresa de salud. Tras explotar vulnerabilidades de ejecución remota de código (RCE) en aplicaciones y sistemas legados, los atacantes lograron acceder a intérpretes de comandos del sistema operativo, lo que les permitió ejecutar scripts maliciosos, administrar procesos y mantener control sobre los sistemas comprometidos. Esta técnica fue empleada por el grupo atacante para facilitar el control remoto, la ejecución de malware y la preparación del entorno para el movimiento lateral dentro de la red interna.
2.Exploitation of remote services	Los atacantes aplicaron la técnica Exploitation of Remote Services al aprovechar vulnerabilidades presentes en servicios expuestos y sistemas accesibles de forma remota dentro de la infraestructura de la empresa. Mediante la explotación de fallas críticas en servidores con

	software desactualizado, lograron acceder a sistemas internos y posteriormente desplazarse lateralmente hacia otros servidores que contenían información clínica sensible. Esta técnica fue utilizada por los ciberatacantes para expandir su presencia dentro de la red corporativa, escalar privilegios y alcanzar sistemas críticos sin necesidad de acceso físico.
3.Exfiltration over c2 channel	Durante la fase final del ataque, los ciberatacantes emplearon la técnica Exfiltration Over C2 Channel para extraer información sensible desde la red interna hacia infraestructura externa bajo su control. A través de malware previamente instalado, los datos clínicos obtenidos fueron enviados en pequeños volúmenes cifrados mediante canales de comunicación con servidores de comando y control (C2), con el objetivo de evadir los mecanismos de detección. Esta técnica fue utilizada por el grupo atacante para sustraer información médica confidencial sin generar alertas inmediatas en los sistemas de monitoreo de la organización.

5. **Nivel de riesgo de las vulnerabilidades.** Realice la evaluación de score de riesgo base CVSS 3.1 de 5 de las vulnerabilidades identificadas por los analistas del incidente. Para cada Vulnerabilidad utilice el siguiente formato.

Vulnerabilidad	Remote Code Execution (CVE-2021-44228 - Log4Shell)
Score de Riesgo CVSS	10.0
Vector de Riesgo CVSS	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:H
Descripción: <i>(justifique los criterios aplicados)</i>	La vulnerabilidad CVE-2021-44228 (Log4Shell) corresponde a una ejecución remota de código que puede ser explotada de forma remota a través de la red (AV:N), sin requerir acceso local ni proximidad al sistema afectado. La explotación presenta una complejidad baja (AC:L), ya que no requiere condiciones especiales más allá de enviar una solicitud especialmente diseñada que contenga una cadena maliciosa procesada por la librería Log4j. No se requieren privilegios previos (PR:N) ni interacción del usuario (UI:N), lo que facilita su explotación masiva. El impacto de la vulnerabilidad permite comprometer componentes fuera del alcance de seguridad original de la aplicación afectada, justificando un cambio de alcance (S:C). Además, la explotación exitosa permite el acceso completo a la información (C:H), la modificación o destrucción de datos (I:H) y la interrupción total del servicio (A:H), lo que resulta crítico en el contexto de una empresa de salud con sistemas clínicos sensibles. Por estos motivos, la puntuación base CVSS asignada es de 10.0 (Crítico).
Imagen de Calculadora CVSS	 The screenshot shows the CVSS Calculator interface with the following settings: Puntuación base: 10.0 (Crítico) Vector de ataque (AV): Red (N) Complejidad de ataque (AC): Bajo (L) Privilegios requeridos (PR): Ninguno (N) Interacción del usuario (UI): Ninguno (N) Alcance (S): Cambiado (C) Confidencialidad (C): Alto (H) Integridad (I): Alto (H) Disponibilidad (A): Alto (H)

Vulnerabilidad	Cross-Site Scripting (XSS) (CVE-2024-340701)
Score de Riesgo CVSS	10.0
Vector de Riesgo CVSS	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:H
Descripción: (justifique los criterios aplicados)	La vulnerabilidad CVE-2024-3407 permite la ejecución remota de código en un dispositivo de perímetro expuesto a Internet, lo que justifica un vector de ataque a través de red (AV:N), sin necesidad de acceso local o físico. La explotación presenta una complejidad baja (AC:L), ya que no requiere condiciones especiales ni configuraciones específicas más allá de la exposición del servicio vulnerable. No se requieren privilegios previos (PR:N) ni interacción del usuario (UI:N), permitiendo su explotación de forma completamente remota y automatizada. El compromiso del dispositivo vulnerable impacta componentes fuera de su ámbito de seguridad original, facilitando el acceso a la red interna de la organización, por lo que se considera un cambio de alcance (S:C). La explotación exitosa permite el acceso no autorizado a información sensible (C:H), la modificación de configuraciones críticas y datos en tránsito (I:H), así como la interrupción de servicios esenciales, tales como conectividad VPN y acceso a sistemas clínicos (A:H). En el contexto de una organización de salud, este nivel de impacto compromete la continuidad operativa y la seguridad de la información clínica, justificando una puntuación base CVSS de 10.0 (Crítico).
Imagen de Calculadora CVSS	 Puntuación base: 10.0 (Crítico) Vector de ataque (AV): Red (N), Adyacente (A), Local (L), Físico (P) Complejidad de ataque (AC): Bajo (L), Alto (H) Privilegios requeridos (PR): Ninguno (N), Bajo (L), Alto (H) Interacción del usuario (UI): Ninguno (N), Requerido (R) Alcance (S): Sin cambios (U), Cambiado (C) Confidencialidad (C): Ninguno (N), Bajo (L), Alto (H) Integridad (I): Ninguno (N), Bajo (L), Alto (H) Disponibilidad (A): Ninguno (N), Bajo (L), Alto (H)

Vulnerabilidad	Desbordamiento de búfer (CVE-2018-5678):
Score de Riesgo CVSS	10.0
Vector de Riesgo CVSS	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:H
Descripción: (justifique los criterios aplicados)	La vulnerabilidad CVE-2018-5678, correspondiente a un desbordamiento de búfer en un módulo de integración expuesto, permite la ejecución de código arbitrario con privilegios elevados. En el contexto del caso de estudio, el componente vulnerable se encuentra accesible desde la red y puede ser explotado remotamente, con baja complejidad, sin requerir autenticación ni interacción del usuario, lo que justifica los criterios AV: Network, AC: Low, PR: None y UI: None. El alcance se considera Changed, ya que la explotación del desbordamiento permite comprometer el sistema operativo y otros servicios más allá del módulo afectado, habilitando control total del servidor y facilitando el movimiento lateral dentro de la infraestructura. En el escenario descrito, esta vulnerabilidad permitió a los atacantes obtener acceso de administrador y avanzar hacia sistemas internos críticos. Respecto al impacto, la confidencialidad, integridad y disponibilidad se clasifican como Altas, dado que el control completo del sistema permite acceder, modificar o destruir información sensible, así como interrumpir servicios críticos del entorno de salud. Considerando la criticidad del sector y el rol de esta vulnerabilidad en la cadena de ataque, se justifica un CVSS Base Score de 10.0 (Crítico) para la CVE-2018-5678 en el contexto del incidente analizado.
Imagen de Calculadora CVSS	Calculadora del Sistema Común de Puntuación de Vulnerabilidades (VCS) versión 3.0 Pase el cursor sobre los nombres de los grupos de métricas, los nombres de las métricas y los valores de las métricas para un resumen de la información del documento oficial de especificación de CVSS v3.0. La especificación está disponible en la lista de enlaces de la izquierda, con junto una Guía del usuario con información adicional sobre la puntuación, un documento de ejemplos de palabras y propuestas y propuestas sobre el uso de uso de estera (s) incluido diseño y una XML para CVSS v3.0). The screenshot shows the CVSS Calculator interface with the following settings: Base de la Puntuación: 10.0 (Crítico) Vector de ataque (AV): Rojo (N), Adyacente (A), Local (L), Físico (P) Complejidad de ataque (AC): Bajo (L), Alto (H) Privilegios requeridos (PR): Ninguno (N), Bajo (L), Alto (H) Interacción del usuario (UI): Ninguno (N), Requerido (R) Alcance (S): Cambios de pecado (U), Cambiado (C) Confidencialidad (C): Ninguno (N), Bajo (L), Alto (H) Integridad (I): Ninguno (N), Bajo (L), Alto (H) Disponibilidad (A): Ninguno (N), Bajo (L), Alto (H)

Vulnerabilidad	<u>CVE-2010-1999</u>
Score de Riesgo CVSS	9.9
Vector de Riesgo CVSS	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:H
Descripción: (justifique los criterios aplicados)	La vulnerabilidad CVE-2010-1999, correspondiente a una File Inclusion en aplicaciones web PHP, fue evaluada considerando el contexto del caso de estudio, en el cual un sistema legado crítico del sector salud se encontraba expuesto a Internet. La explotación puede realizarse de forma remota, sin requerir privilegios ni interacción del usuario, y presenta una baja complejidad técnica, lo que facilita su aprovechamiento por parte de atacantes externos. Estas características justifican la selección de los criterios AV: Network, AC: Low, PR: None y UI: None. El alcance se considera Changed, ya que la explotación de la vulnerabilidad permite la inclusión de archivos y la ejecución de código en el servidor, afectando recursos más allá del componente vulnerable, como el sistema operativo y otros servicios internos. En el contexto del caso, esta vulnerabilidad fue utilizada como punto de entrada para el movimiento lateral dentro de la red, facilitando el acceso a bases de datos y sistemas que contienen información clínica sensible. Respecto al impacto, la confidencialidad se clasifica como Alta, debido al riesgo directo de exposición de datos médicos y personales de pacientes. La integridad y disponibilidad se consideran Bajas, ya que, si bien no se evidenció una alteración masiva de la información ni una interrupción directa del servicio, la ejecución de código no autorizado implica un riesgo potencial sobre la operación y estabilidad del sistema. En conjunto, estos factores justifican un CVSS Base Score de 9.9 (Crítico) para esta vulnerabilidad en el escenario analizado.
Imagen de Calculadora CVSS	

Vulnerabilidad	Insufficient Authentication (CVE-2020-13942)
-----------------------	---

Score de Riesgo CVSS	9.3
Vector de Riesgo CVSS	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:H
Descripción: (justifique los criterios aplicados)	La vulnerabilidad CVE-2020-13942, presente en Apache OFBiz, permite la ejecución de código arbitrario debido a una autenticación insuficiente, lo que posibilita a un atacante remoto ejecutar comandos sin credenciales válidas. En el contexto del caso de estudio, el sistema afectado se encuentra expuesto a Internet y forma parte de la infraestructura crítica de la organización, por lo que la explotación puede realizarse de forma remota, con baja complejidad, sin privilegios previos ni interacción del usuario, justificando los criterios AV: Network, AC: Low, PR: None y UI: None. El alcance se considera Changed, ya que la explotación de esta vulnerabilidad permite tomar control del servidor de aplicaciones y afectar componentes fuera del software vulnerable, incluyendo el sistema operativo y otros sistemas internos. En el escenario analizado, este tipo de acceso facilita el movimiento lateral dentro de la red y la persistencia del atacante, aumentando significativamente el impacto del incidente. Respecto al impacto, la disponibilidad se clasifica como Alta, dado que la ejecución de comandos no autenticados puede provocar interrupciones graves del servicio, caída de sistemas o preparación de ataques posteriores como ransomware. La integridad se evalúa como Baja, considerando la posibilidad de modificación de configuraciones o archivos, mientras que la confidencialidad se mantiene como Nula, ya que en el caso específico no se evidenció un acceso directo a datos sensibles a través de esta vulnerabilidad en particular. En conjunto, estos factores justifican un CVSS Base Score de 9.3 (Crítico) para la CVE-2020-13942 dentro del contexto del incidente descrito.
Imagen de Calculadora CVSS	 The screenshot shows the CVSS Calculator interface with the following settings: Base de la Puntuación: 9.3 (Crítico) Vector de ataque (AV): Rojo (N) [Adyacente (A)] [Local (L)] [Físico (P)] Complejidad de ataque (AC): Bajo (L) [Alto (H)] Privilegios requeridos (PR): Ninguno (N) [Bajo (L)] [Alto (H)] Interacción del usuario (UI): Ninguno (N) [Requerido (R)] Alcance (S): [Cambios de pecado (U)] Cambiado (C) Confidencialidad (C): Ninguno (N) [Bajo (L)] [Alto (H)] Integridad (I): Ninguno (N) Bajo (L) [Alto (H)] Disponibilidad (A): Ninguno (N) [Bajo (L)] Alto (H)

Conclusión

La evidencia analizada demuestra que el incidente afectó de forma crítica la confidencialidad, integridad y disponibilidad de la información clínica, principalmente debido a la presencia de sistemas legados, falta de parcheo oportuno, debilidades en autenticación y monitoreo insuficiente. A través del uso de marcos metodológicos como STRIDE, OWASP Top Ten, MITRE ATT&CK y CVSS 3.1 fue posible identificar amenazas relevantes, caracterizar riesgos, reconocer tácticas y técnicas empleadas por los atacantes y evaluar de forma objetiva el impacto potencial sobre la organización.

En base a los hallazgos, el nivel de riesgo global puede considerarse alto, dado que las vulnerabilidades explotadas permitieron intrusión, movimiento lateral, exfiltración de datos y potencial afectación operativa. Como recomendación general, la organización debe avanzar hacia una estrategia de ciberseguridad proactiva, fortaleciendo la gestión de vulnerabilidades, modernizando los sistemas legados, implementando segmentación de red, controles de acceso robustos, monitoreo continuo y planes formales de continuidad operacional. Solo mediante un enfoque integral y sostenido será posible reducir la exposición a futuros incidentes y proteger adecuadamente la información clínica y la confianza institucional.

Bibliografía

Qilin Ransomware: De La Disrupción Sanitaria Al Ciberconflicto Global. (2025, July 3). *CronUp Ciberseguridad*. <https://www.cronup.com/qilin-ransomware-de-la-disrupcion-sanitaria-al-ciberconflicto-global/>.

MITRE ATT&CK®. (n.d.). Mitre.org. Retrieved December 29, 2025, from <https://attack.mitre.org/>.

Common vulnerability scoring system version 3.0 calculator. (n.d.). FIRST — Forum of Incident Response and Security Teams. Retrieved December 29, 2025, from <https://www.first.org/cvss/calculator/3-0>.

NVD - home. (n.d.). Nist.gov. Retrieved December 29, 2025, from <https://nvd.nist.gov/>.